

Review: Pinning Is Futile

Marcelo Astete Chávez

1. Problema que se está resolviendo

El problema que se está resolviendo es la vulnerabilidad de los ecosistemas de software, específicamente en la gestión de dependencias, que puede permitir actualizaciones maliciosas de paquetes. Se busca mejorar la resiliencia de estos ecosistemas mediante la fijación de dependencias para reducir el riesgo de conflictos y ataques. Además, se investiga cómo la coordinación en la fijación de paquetes puede mitigar estos riesgos a nivel de ecosistema.

2. Idea Propuesta

La nueva idea propuesta es implementar una fijación coordinada en un pequeño conjunto de paquetes "principales" que actualicen rápidamente todas sus dependencias tras una auditoría adecuada. Esto permitiría reducir significativamente el riesgo de actualizaciones maliciosas en el ecosistema NPM, al asegurar que no haya dependencias obsoletas ni actualizaciones dañinas. Se sugiere que esta estrategia de colaboración en la fijación de dependencias sería más eficiente que intentar convencer a cada mantenedor individualmente.

3. Puntos Positivos

- **Eficiencia en la Seguridad:** La fijación coordinada de dependencias puede reducir significativamente el riesgo de actualizaciones maliciosas, mejorando la seguridad del ecosistema.
- **Optimización de Recursos:** Al enfocarse en un número limitado de paquetes principales, se simplifica el proceso de auditoría y actualización, haciendo un uso más efectivo de los recursos.
- **Estabilidad Aumentada:** La estrategia puede contribuir a una mayor estabilidad y reproducibilidad en las aplicaciones, al minimizar conflictos y vulnerabilidades en las dependencias.

4. Puntos Negativos

- **Ineficacia en Proyectos Grandes:** La fijación de dependencias puede resultar contraproducente en gráficos de dependencias grandes, aumentando la exposición a vulnerabilidades de seguridad.
- **Generación de Dependencias Flotantes:** La fijación puede crear más dependencias flotantes, lo que permite a los atacantes explotar versiones inseguras de dependencias indirectas.
- **Desafíos de Coordinación:** La implementación de una fijación coordinada entre múltiples mantenedores puede ser compleja y

difícil de gestionar, lo que podría limitar su efectividad y adopción.

5. Trabajo Futuro

Investigación en Estrategias de Fijación: Se sugiere explorar y desarrollar nuevas estrategias de fijación que se adapten a diferentes tipos de proyectos y ecosistemas de software, considerando la diversidad de gráficos de dependencias.

Colaboración entre Mantenedores: Fomentar la colaboración entre mantenedores de paquetes para establecer prácticas de fijación y actualización más seguras y efectivas, creando un marco común de seguridad.

Evaluación de Impacto: Realizar estudios empíricos para evaluar el impacto de la fijación coordinada en la seguridad y estabilidad del software, así como en la experiencia del desarrollador, para ajustar las estrategias propuestas.

6. Calificación (1 a 5)

La calificación para este artículo es nota 4 debido a que se debería considerar el manejo del impacto al implementar la idea propuesta.

7. Puntos de Discusión

Controversia entre Fijación y Flotación: Discutir las fuertes convicciones de ambos lados sobre la fijación de dependencias versus la flotación, y cómo estas posturas generan controversia entre profesionales de la ingeniería de software y seguridad.

Impacto de Actores Maliciosos: Analizar cómo los actores maliciosos pueden explotar el control de versiones semántico, disfrazando ataques como actualizaciones legítimas, y las implicaciones de esto para la seguridad del software.

Compensaciones en Estrategias de Seguridad: Evaluar las compensaciones entre la seguridad y el mantenimiento en la fijación y flotación de dependencias, y cómo estas decisiones afectan a los usuarios y desarrolladores en la práctica.